Phase 4: Incident Response & Automation

Organization: CryptoVault Exchange

Team: Kaveri Sharma (PES1UG23CS293) & Anvita Kulkarni (PES1UG23CS092)

---

1. Incident Scenario Description

Organization Context: CryptoVault is a high-frequency digital asset exchange. It utilizes a 4-zone network architecture to isolate its "Hot Wallet" (Asset A-01) from the public internet. The SOC monitors this environment 24/7 to prevent unauthorized asset transfers.

How the Incident Started: An IT Administrator was targeted via a spear-phishing email containing a macro-enabled invoice. Upon execution, a PowerShell-based ransomware loader established a Command and Control (C2) connection, allowing the attacker to move laterally from the Admin Jump Server into the secure Wallet Zone.

Systems Affected:

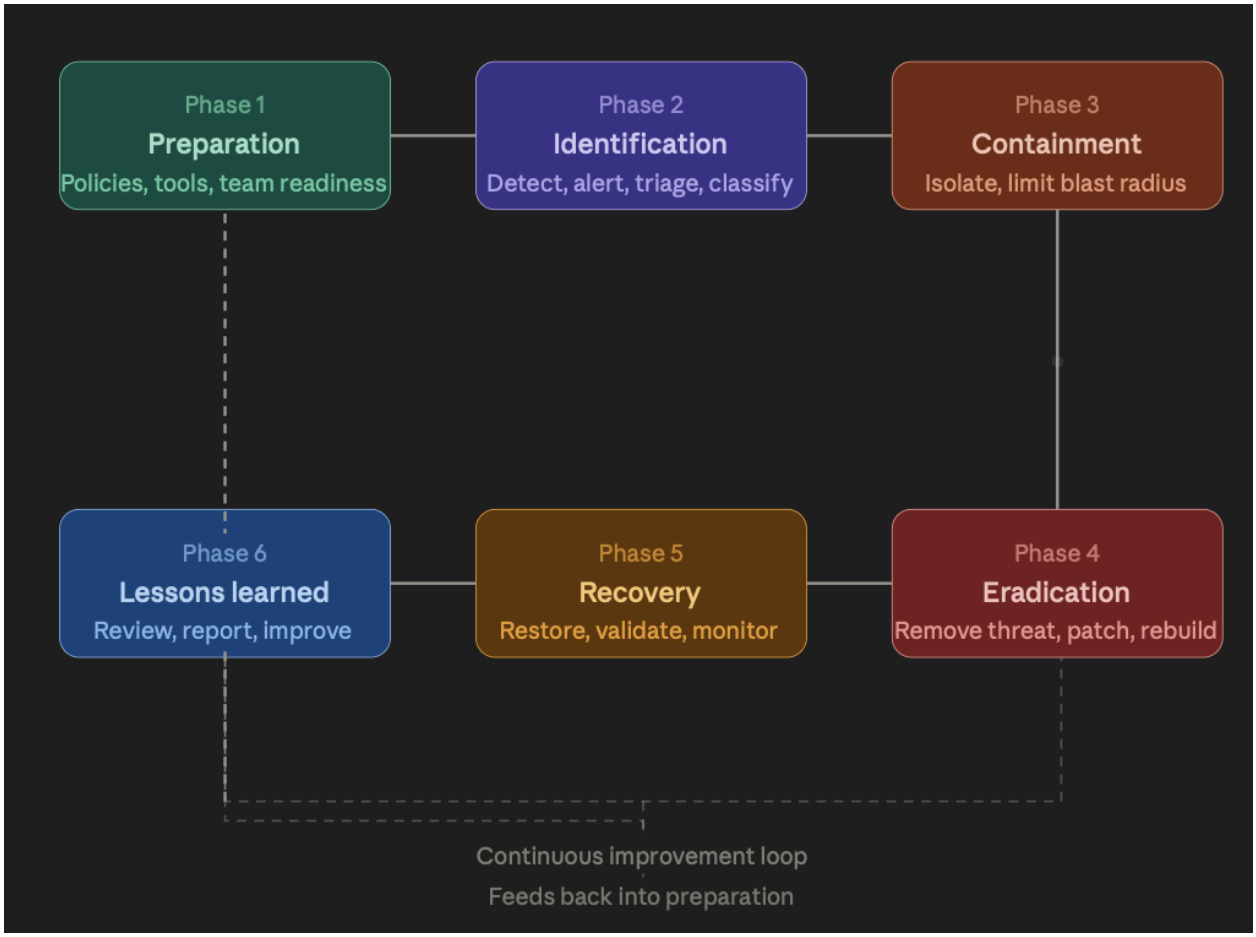
- Admin Workstation (Patient Zero)
- Internal Jump Server (Zone 3)
- Hot Wallet Production Server (Zone 4)

Initial Symptoms (Alerts/Logs):

- **EDR Alert:** "Suspicious PowerShell execution detected" on Admin Workstation.
- **SIEM Alert:** "Secure Vault Beaconing" (DNS Tunneling detected from Zone 4).
- **Application Log:** Rapid file encryption (rename operations) detected on the Wallet filesystem.

2. IR Lifecycle Mapping

Lifecycle Flow Diagram



Written Explanation

IR Phase	Actions Taken	Responsible Role	Evidence Collected

Preparation	Hardening Zone 4 and configuring SIEM correlation rules.	SOC Manager / Engineering	Baseline config files, Playbooks.
Identification	Triage of DNS Tunneling alerts and EDR process tree analysis.	Tier-1 Analyst	SIEM Logs, PCAP of DNS traffic.
Containment	Isolate Jump Server via EDR and execute API "Wallet Freeze."	Tier-2 Responder	Firewall block logs, EDR status.
Eradication	Purging malicious scheduled tasks and rotating admin credentials.	IR Lead	Malware samples, AD Change logs.
Recovery	Rebuilding Wallet Server from gold image and restoring DB.	Tier-2 / IT Ops	Integrity scan reports.
Lessons Learned	Post-mortem meeting to improve phishing filters and MFA.	IR Lead	Final Incident Report.

3. Severity & Prioritization Matrix

Mandatory Matrix Format

Severity Level	Impact	Urgency	Example Incident	Response Time
Low	Minimal; no data risk.	Low	Single failed login attempt.	24 Hours
Medium	Partial service risk.	Medium	Malware on non-critical laptop.	4 Hours
High	Critical service risk.	High	DDoS on exchange frontend.	30 Minutes
Critical	**Financial/Data loss.**	**Immediate**	**Ransomware on Wallet Server.**	**5 Minutes**

Justification: This incident is **Critical** because it involves the potential exfiltration of private keys. Any delay results in irreversible financial loss and total loss of customer trust.

4. IR Playbook

Playbook Structure

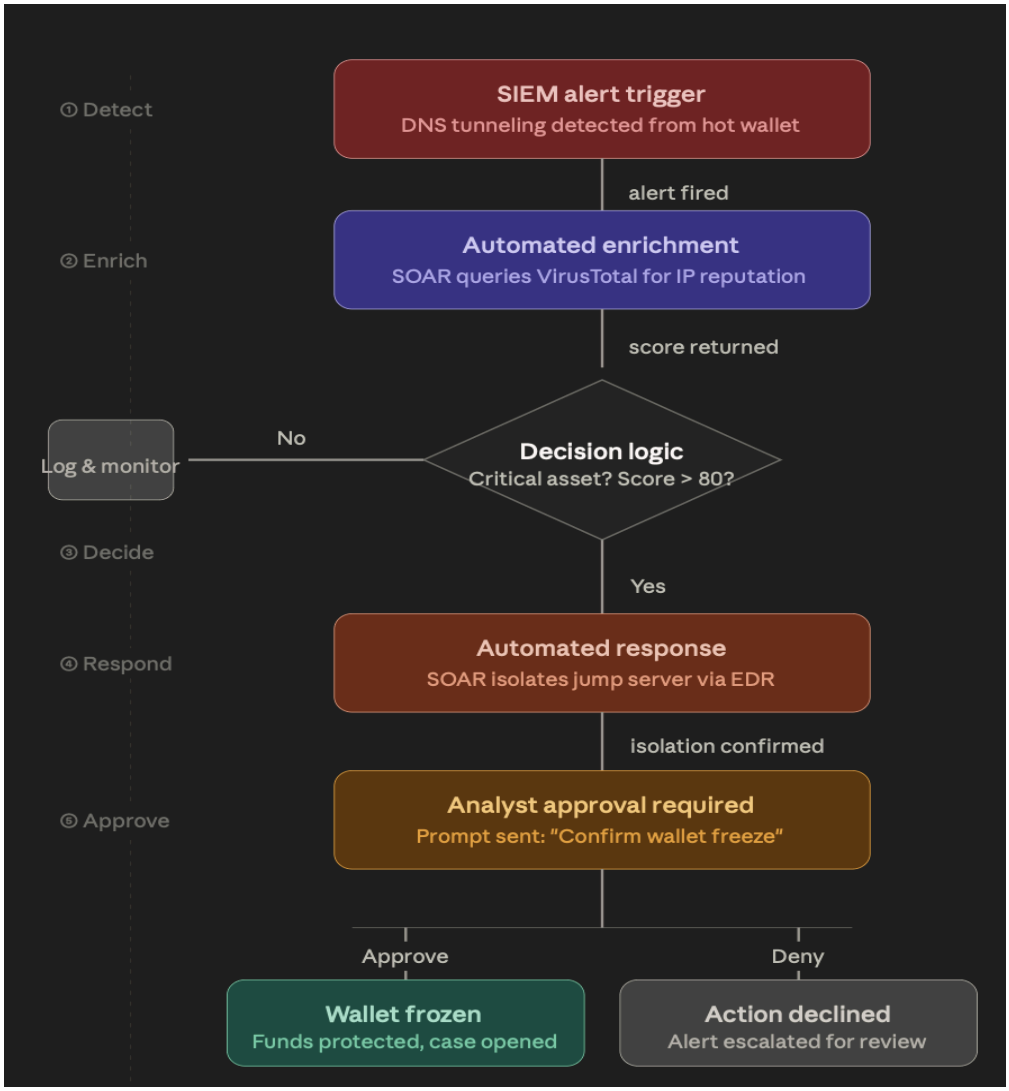
Step No.	Action	Responsible Role	Tools / Logs Used	Expected Outcome

1	Alert Triage	Tier-1 Analyst	SIEM Dashboard	Verify True Positive.
2	Initial Scoping	Tier-1 Analyst	EDR Console	Identify affected hosts.
3	Communication	IR Lead	Slack / PagerDuty	Stakeholders notified.
4	Asset Isolation	Tier-2 Responder	EDR Isolation Tool	Stop lateral movement.
5	Wallet Freeze	Tier-2 Responder	Application Admin API	Transactions halted.
6	Evidence Capture	Tier-2 Responder	FTK Imager / RAM dump	Forensic data saved.
7	Credential Reset	IR Lead	Active Directory	Attacker access revoked.
8	Malware Removal	Tier-2 Responder	Antivirus / Scripts	Malicious files deleted.

9	System Restore	IT Ops	Backup/DR Tool	Service restored.
10	Post-incident Review	SOC Manager	Incident Ticket	Documentation complete.

5. SOAR Conceptual Flow

SOAR Flow Diagram



Written Explanation

- **Automated Steps:** The SOAR can automatically perform IP reputation checks and isolate the Admin Workstation the moment the ransomware behavior is detected.
- **Human Approval:** Freezing the Hot Wallet requires an **Analyst Approval** click in Slack to prevent accidental business disruption.
- **Benefits:** This ensures a sub-5-minute response, providing the **speed** and **consistency** necessary to save digital assets from theft.